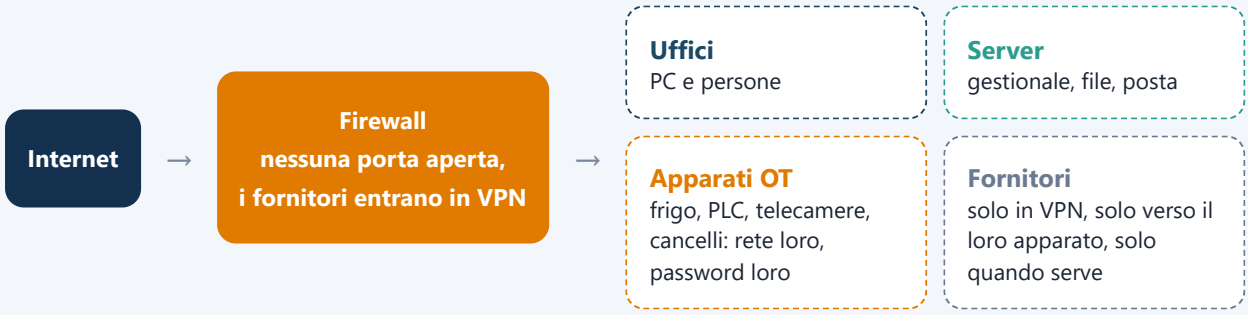
SPECIALE 1

Le macchine che nessuno considera informatica: l'OT in azienda

Frigoriferi, macchine di produzione, cancelli, telecamere: comandano cose fisiche e stanno in rete. Le installa chi non fa reti, e poi nessuno le guarda più. Questa lezione serve a trovarle, a capire cosa parlano e dove sono deboli, e a fare l'audit da soli prima di chiudere la porta.

fuori serie

A COLPO D'OCCHIO



Gli apparati che comandano cose fisiche stanno in una zona loro. Da internet non si raggiungono; il fornitore ci arriva dalla VPN, acceso quando serve.

Cos'è l'OT, detto semplice

L'informatica che conosci elabora dati: gestionale, posta, file. L'OT (Operational Technology) comanda **oggetti fisici**: la temperatura di un frigorifero, un cancello, una linea di produzione, una pompa, le luci, l'impianto di condizionamento. Dentro ognuna di queste cose c'è un piccolo computer, con una pagina web per configurarlo e spesso un modo per raggiungerlo da fuori.

In una PMI ce n'è più di quanto si pensi:

Cosa	Chi l'ha installato	Come si gestisce di solito
Centrale frigo, celle, banchi	il frigorista	pagina web del controllore, raggiungibile anche dal fornitore

Cosa	Chi l'ha installato	Come si gestisce di solito
Macchine di produzione, PLC di linea	il costruttore o il manutentore	teleassistenza del fornitore, a volte con un router 4G suo
Condizionamento, caldaie, UPS	l'impiantista	pagina web, app del produttore
Telecamere e videoregistratore (NVR)	chi fa l'allarme	app del produttore che passa dal cloud, oppure porta aperta sul router
Cancelli, badge, controllo accessi	chi fa l'allarme o l'elettricista	software su un PC in portineria, a volte in rete
Inverter del fotovoltaico, contatori	l'installatore	portale del produttore, collegamento sempre acceso

Nessuna di queste cose è stata installata da uno di reti, e non è un difetto di chi le ha installate: non è il suo mestiere. Il punto è che poi restano lì, in rete, e nessuno le considera parte dell'informatica. Quando si fa l'inventario della lezione 1, raramente ci finiscono.

Il caso di queste settimane: i frigoriferi dei supermercati

Nella notte fra l'11 e il 12 ottobre 2026, in Francia, qualcuno è entrato dall'esterno nei controllori che comandano la refrigerazione di centinaia di supermercati e ha cambiato temperature e cicli di sbrinamento. Banchi da svuotare, merce da buttare. Il 12 ottobre il CERT-FR, il centro di risposta dell'agenzia francese, ha pubblicato un'allerta: parlava di «numerose compromissioni» di controllori remoti per impianti di refrigerazione, e scriveva una frase che vale per tutta questa lezione: **esporre un'interfaccia di gestione su internet è contrario alle buone pratiche.**

Le contromisure che indicava stanno in poche righe, e sono quelle che trovi in fondo a questa lezione: togliere gli apparati da internet, tutti quelli raggiungibili da un indirizzo pubblico; rimettere l'accesso solo attraverso una VPN; cambiare le password di fabbrica e aggiornare il firmware; ricontrollare la configurazione, in particolare i cicli di sbrinamento; se l'apparato era già compromesso, riavviarlo o riportarlo alle impostazioni di fabbrica e riconfigurarlo. E un avvertimento: un apparato fuori supporto lasciato esposto verrà compromesso di nuovo, anche dopo la pulizia.

Nei giorni successivi anche l'Agenzia per la cybersicurezza nazionale (ACN) ha pubblicato misure urgenti per la distribuzione alimentare e la filiera del freddo. Poi, ai primi di novembre, la stessa cosa è successa in altri paesi europei e in Italia, in decine di punti vendita. Il 4 novembre ACN ha richiamato gli operatori alle misure già pubblicate, e ha aggiunto una riga che vale anche per te: in presenza di anomalie, si attiva la gestione dell'incidente e si segnala al CSIRT Italia.

Fra l'allerta francese e gli attacchi in Italia sono passate tre settimane. In tre settimane si fa in tempo a farsi le domande giuste: ho anch'io un apparato così? È raggiungibile da fuori? Chi lo gestisce lo sa? Con che password?

Perché l'OT è più esposto dell'informatica, non meno

- **È stato messo online «per gestirlo da remoto».** Il tecnico apre una porta sul router verso la pagina web dell'apparato, così interviene senza venire in sede. Funziona, e nessuno la richiude.
- **Ha la password di fabbrica.** Il manuale è su internet, e con lui la password.
- **Non si aggiorna.** Aggiornare il firmware di un controllore fa paura: se qualcosa va storto si ferma la linea, o si scongela il banco. Così resta la versione del giorno dell'installazione, per anni.
- **Vive quindici anni.** Un PC si cambia ogni cinque. Un PLC resta finché funziona la macchina, e il produttore smette di correggerlo molto prima.
- **Parla protocolli nati senza sicurezza.** Nel prossimo paragrafo ci sono i principali. Quasi tutti non prevedono una password: chi è in rete con l'apparato può leggere e scrivere.
- **Nessuno sa che c'è.** L'ha installato un fornitore, lo gestisce il fornitore, l'IT non lo vede nell'inventario. A volte ha un router 4G suo, e non passa nemmeno dal tuo firewall.

Niente di tutto questo è colpa di chi ha montato l'apparato. È il risultato di una cosa installata da chi fa un altro mestiere, in una rete che nessuno ha disegnato.

I protocolli: cosa parlano gli apparati, e cosa manca

Ogni apparato parla in rete con un protocollo, e il protocollo ti dice tre cose: da che porta lo riconosci, cosa può fare chi riesce a parlargli, e che difesa ha dentro. Quasi sempre la terza colonna è vuota.

Protocollo (porta)	Dove lo trovi	Cosa fa chi lo raggiunge	Difesa incorporata
Modbus/TCP (502)	PLC, controllori frigo, inverter, contatori, UPS, quadri	legge e scrive i registri: un setpoint, un'uscita, un comando	nessuna: niente password, niente cifratura
S7comm (102)	PLC Siemens	legge e scrive le variabili, ferma il PLC, carica un programma	nelle versioni classiche nessuna; le recenti hanno una protezione a livelli, spesso lasciata spenta
EtherNet/IP, CIP (44818, 2222)	PLC e azionamenti di scuola americana	legge e scrive i dati, riavvia l'apparato	nessuna nella versione diffusa; la variante cifrata è rara
BACnet/IP (47808 UDP)	condizionamento, caldaie, impianti dell'edificio	legge e cambia temperature, orari, allarmi	nessuna nella versione diffusa
DNP3 (20000)	energia, acqua, cabine	comandi sulle apparecchiature	esiste una variante con autenticazione, raramente attiva
OPC UA (4840)	supervisori e macchine recenti	legge e scrive i dati dell'impianto	sì: certificati e cifratura, ma si trova spesso configurato su «nessuna sicurezza»

Protocollo (porta)	Dove lo trovi	Cosa fa chi lo raggiunge	Difesa incorporata
MQTT (1883; 8883 cifrato)	sensori, gateway IoT, inverter, monitoraggio	pubblica e legge i messaggi	password e cifratura facoltative; su 1883 tutto passa in chiaro
PROFINET (senza IP)	PLC e moduli I/O di linea	—	non attraversa il router: si vede solo da dentro la stessa rete

Il punto che conta sta nella terza colonna: in Modbus e nella maggior parte di questi protocolli **una scrittura è un comando**. Il registro che contiene la temperatura di un banco si scrive con la stessa richiesta con cui la scrive il supervisore del frigorista, e l'apparato non ha modo di distinguere i due. Non c'è una falla da correggere: è il disegno del protocollo, fatto per reti chiuse degli anni Settanta e Ottanta. Per questo la difesa non sta nell'apparato ma nella rete: l'unico che può parlare Modbus al controllore è il PC di supervisione, e nessun altro. La norma dell'OT, la IEC 62443, chiama questa cosa **zone e condotti**: gli apparati stanno in una zona, e fra una zona e l'altra passa solo quello che è scritto nel condotto.

Sugli stessi apparati girano poi i protocolli «normali», e sono spesso quelli che aprono la porta:

- **La pagina web di gestione** su HTTP (80), in chiaro: la password passa leggibile sulla rete. HTTPS (443) c'è di rado, e quando c'è ha un certificato di fabbrica.
- **Telnet** (23): una riga di comando in chiaro, a volte con una password fissa che non si può cambiare.
- **SNMP** versione 1 e 2c (161 UDP): con la parola «public» chiunque legge la configurazione, con «private» la scrive. Sono le parole di fabbrica.
- **FTP e TFTP** (21, 69): per caricare firmware e configurazioni. TFTP non chiede nemmeno una password.
- **VNC** (5900) sui pannelli HMI e **RDP** (3389) sui PC di supervisione: il primo spesso senza password, il secondo su un Windows che non si aggiorna da anni.
- **RTSP** (554) e **ONVIF** sulle telecamere: il flusso video e i comandi; più le porte proprietarie dei produttori (per esempio 37777 e 8000), che da fuori dicono subito la marca, e quindi quali falle provare.

Quando nel giro del firewall trovi una regola che porta a una di queste porte, ora sai cosa c'è dietro e cosa può fare chi ci arriva.

Le debolezze tipiche, per famiglia

Negli apparati OT le vulnerabilità si ripetono. Non serve conoscere le singole CVE: servono le dieci famiglie, come si presentano da te e cosa le chiude.

Famiglia	Come si presenta da te	Cosa la chiude
1 · Interfaccia di gestione esposta su internet	una regola di inoltro sul firewall verso la pagina web o il VNC dell'apparato; è il caso dei frigoriferi di ottobre	togliere l'inoltro; il fornitore entra in VPN

Famiglia	Come si presenta da te	Cosa la chiude
2 · Credenziali di fabbrica o condivise	admin/admin, 1234, oppure la stessa password che l'installatore usa da tutti i suoi clienti	cambiarle; un utente per fornitore; scritte in un posto solo
3 · Protocollo senza autenticazione raggiungibile da chi non deve	dalla VLAN degli uffici si arriva alla porta 502 del PLC; un PC infetto in ufficio può scrivere un registro	zona separata e firewall in mezzo: solo il supervisore parla con il PLC
4 · Firmware con falle note mai corrette	la versione è quella del giorno dell'installazione; il produttore e CISA hanno pubblicato avvisi da allora	confrontare la versione con gli avvisi; aggiornare in finestra concordata; se fuori supporto, isolare
5 · Servizi in chiaro	HTTP, Telnet, FTP, SNMP v1/v2c accesi: le password passano leggibili (lezione 10)	spegnerli dove si può, usare le versioni cifrate; altrimenti isolare
6 · Accesso remoto del fornitore fuori controllo	un programma di teleassistenza sempre acceso sul PC di supervisione, un router 4G, una VPN del fornitore sempre su	accesso a richiesta, su quello che serve, registrato, revocato a fine intervento
7 · Porte aperte da sole	UPnP acceso sul router: le telecamere e il videoregistratore si aprono la porta da soli; le app «cloud» aprono un tunnel da dentro	UPnP spento sul router; app cloud solo se decise e documentate
8 · Fragilità	una scansione di porte o un pacchetto malformato bloccano il PLC; chi lo raggiunge può fermarlo senza nemmeno una password	non scansionare dall'IT; separare prima; chi lo raggiunge dev'essere solo chi deve
9 · PC di supervisione vecchio	un Windows fuori supporto con il software dell'impianto, con la posta aperta e una chiavetta USB nel cassetto	niente internet e niente posta; solo le applicazioni dell'impianto; backup
10 · Nessun log	nessuno sa chi ha cambiato il setpoint, né quando	accendere i log dove ci sono; almeno il registro degli accessi VPN dei fornitori

Le prime due sono esattamente quelle degli attacchi di ottobre e novembre: interfacce esposte e password di fabbrica. Non è una novità: nel 2016 la botnet Mirai era fatta di telecamere e videoregistratori con la password di fabbrica, e dieci anni dopo si entra ancora così. Le altre otto sono quelle che un attaccante usa dopo, una volta dentro, oppure quelle che un PC infetto in ufficio trova senza cercarle.

L'audit, primo livello: tre giri senza strumenti

Non servono strumenti. Servono tre giri.

1. **Il giro delle persone.** Chiama chi ti fa manutenzione: frigorista, elettricista, chi segue l'allarme, chi segue la linea, chi ha messo il fotovoltaico. Una domanda sola: «come lo raggiungi da fuori quando devi intervenire?». Le risposte sono la tua mappa: una porta aperta sul router, una app che passa dal cloud del produttore, un router 4G suo, una VPN.
2. **Il giro del firewall.** Apri l'elenco delle regole di inoltro delle porte (NAT, port forwarding, «server virtuali»). Ogni riga che porta a un indirizzo interno è una porta aperta da fuori. Per ognuna scrivi a cosa porta e chi l'ha chiesta, e con la tabella dei protocolli sai cosa c'è dietro. Quelle di cui nessuno sa niente sono le prime da chiudere. Nello stesso giro guarda se UPnP è acceso e l'elenco delle porte che ha aperto lui.
3. **Il giro della rete.** Dalla tabella degli indirizzi assegnati dal DHCP e dalle tabelle degli switch vedi tutto quello che è collegato. Gli apparati OT si riconoscono dal nome del produttore nell'indirizzo fisico (MAC) e dal fatto che nessuno sa cosa siano. Nella lezione 8 c'è come si legge questa mappa.

L'elenco che ne esce ha cinque colonne: cos'è, dove sta, chi lo gestisce, come si raggiunge da fuori, se la password di fabbrica è stata cambiata. È lo stesso inventario che ACN chiede agli operatori della filiera del freddo, con le parole loro: controllori, SCADA, HMI, gateway, piattaforme di monitoraggio, servizi di teleassistenza, compresi i router cellulari e i collegamenti predisposti dai manutentori.

L'audit, secondo livello: guardarsi da fuori

Il primo livello dice cosa credi di avere esposto. Il secondo dice cosa vede davvero chi sta su internet, e le due liste non coincidono quasi mai.

- **Cerca il tuo indirizzo pubblico su Shodan o Censys.** Sono motori di ricerca che scandagliano internet di continuo e tengono in memoria cosa risponde su ogni indirizzo. Sul tuo indirizzo è legale e gratuito. Ti mostrano le porte aperte, il banner con marca e modello, e per i protocolli industriali anche l'identità che l'apparato dichiara: Shodan riconosce Modbus, S7, BACnet e gli altri, e dei pannelli web salva perfino la schermata. Quello che vedi tu lo vede chiunque, da mesi.
- **Confronta con l'elenco del firewall.** Una porta che Shodan vede e che nel firewall non c'è ha due spiegazioni: l'ha aperta UPnP, oppure c'è un secondo accesso a internet, di solito il router 4G di un fornitore. In quel caso l'indirizzo pubblico non è nemmeno il tuo: va chiesto al fornitore e cercato anche quello.
- **Una scansione da fuori** verso il tuo indirizzo, fatta da una connessione esterna (un server in affitto, il telefono in hotspot), serve solo a confermare: tutte le porte, in sola connessione, senza riconoscimento di versione. Ogni porta che risponde arriva a un apparato dentro, quindi niente di più di un collegamento e via.
- **Guarda cosa esce.** Dai log del firewall, i collegamenti in uscita partiti dagli indirizzi degli apparati: verso il portale del produttore va bene, se è documentato; verso tutto il resto, no.

Alla fine di questo livello hai la lista delle porte da chiudere, e di solito è più lunga di quella del primo.

L'audit, terzo livello: da dentro

Da dentro si lavora **prima in ascolto, poi, solo se serve, toccando**. È la regola che distingue un audit OT da un audit IT.

In ascolto. Dalla porta di copia dello switch (SPAN, lezione 11) o da una derivazione passiva sul segmento OT, registri il traffico per una settimana con Wireshark. Wireshark decodifica Modbus, S7comm, BACnet, DNP3 ed EtherNet/IP: con i filtri `modbus`, `s7comm`, `bacnet`, `dnp3`, `enip` vedi chi parla con chi, e in Modbus vedi perfino i codici di funzione, cioè se una richiesta legge o scrive. Ne esce una mappa delle conversazioni: il supervisore che interroga i controllori ogni pochi secondi, il controllore che chiama il portale del produttore, e poi gli altri. Ogni **scrittura** verso un PLC che non viene dal supervisore è un risultato dell'audit; ogni apparato che parla con un indirizzo che non sapevi è un altro. Non hai mandato un solo pacchetto, e l'impianto non si è accorto di niente.

Toccando, con cautela. Una scansione attiva sull'OT si fa solo se vale queste cinque condizioni: dopo la separazione in zone; in una finestra concordata con chi mantiene l'impianto; un apparato alla volta; con qualcuno accanto alla macchina; con la configurazione dell'apparato salvata prima. E si fa con il freno: solo connessione, poche porte, lenta, senza riconoscimento di versione né del sistema operativo, senza script:

```
nmap -sT -Pn -p 80,443,23,21,161,502,102,44818,47808,4840,1883,5900 --scan-delay 200ms <indirizzo
>
```

Gli script di nmap che interrogano gli apparati industriali (`modbus-discover`, `s7-info`, `enip-info`, `bacnet-info`) ti restituiscono marca, modello e versione, ed è un'informazione preziosa: ma mandano richieste al protocollo, e su un apparato fragile possono fermarlo. Si usano solo sugli apparati che il fornitore conferma che li reggono. Per tutti gli altri, la versione del firmware la chiedi: al fornitore, o alla pagina web dell'apparato.

Sulla pagina web di ogni apparato. Entri tu, dalla rete giusta, e provi quattro cose: la password di fabbrica dal manuale, l'elenco degli utenti, la versione del firmware, il registro degli accessi se c'è. Poi confronti la versione con gli avvisi del produttore e con gli avvisi ICS che CISA pubblica regolarmente. Se c'è un avviso aperto sulla tua versione, l'apparato è vulnerabile: non serve nessuno strumento per saperlo.

Il PC di supervisione. È un PC come gli altri, e si controlla come nella lezione 1: versione di Windows, aggiornamenti, antivirus, chi ci entra, cosa c'è installato oltre al software dell'impianto, se c'è un programma di teleassistenza sempre acceso. Nove volte su dieci è il punto più debole della zona, perché è l'unico che un attaccante sa già usare.

La scheda per ogni apparato

L'audit finisce quando ogni apparato ha la sua scheda. Dieci righe, nessuna da saltare:

1. Cos'è: marca, modello, versione del firmware, data di installazione.
2. Chi lo mantiene: fornitore, contatto, cosa dice il contratto sull'accesso remoto.
3. Dove sta in rete: indirizzo, VLAN, da dove raggiunge internet (firewall, router 4G, cloud del produttore).
4. Cosa ha in ascolto: porte e protocolli, dal giro della rete o dall'ascolto.
5. Come si raggiunge da fuori: da chi, come, sempre o a richiesta.
6. Credenziali: password di fabbrica cambiata, elenco degli utenti, dove sono custodite.
7. Supporto: ultima versione pubblicata dal produttore, avvisi aperti sulla versione installata.
8. Chi può scrivere: quali indirizzi sono autorizzati a dare comandi, e da quale zona.

9. Log: se c'è, dove va, chi lo guarda.
10. Se si ferma: cosa succede fisicamente, backup della configurazione, come si ripristina.

Le righe 7, 8 e 10 sono quelle che nessuno ha mai compilato. Sono anche quelle che contano la notte in cui succede.

Le norme, in tre righe

Non devi leggerle, devi sapere che esistono, perché i fornitori seri le conoscono e ti aspetti che ne parlino. **IEC 62443** è la norma della sicurezza OT: da lì vengono le zone, i condotti e i livelli di sicurezza, ed è quella da citare quando chiedi a un costruttore di macchine come ha pensato la rete. **NIST SP 800-82**, nella revisione 3, è la guida pratica alla sicurezza OT dell'istituto americano: gratuita, in inglese, con i controlli già adattati agli impianti. Gli **avvisi ICS di CISA** e le misure di **ACN** sono quello che leggi, non quello che consulti: ci si iscrive una volta e si guarda se compare la propria marca.

Un audit OT fatto di mestiere, con strumenti passivi e con chi conosce l'impianto, costa, e per una linea di produzione che se si ferma costa di più ne vale la pena. Quello di questa lezione è l'audit che fai da solo prima, e che ti fa arrivare a quel giorno con le schede già compilate.

Cosa fare, in ordine

Passo	Cosa	Costo
1 · Chiudere la porta	togliere ogni inoltro di porta verso gli apparati; spegnere UPnP sul router; l'accesso da fuori passa dalla VPN, acceso quando il fornitore deve intervenire e spento dopo	mezz'ora sul firewall
2 · Cambiare le password	tutte quelle di fabbrica, scritte in un posto solo; un utente per fornitore, non uno condiviso; comunità SNMP comprese	un'ora
3 · Separare	gli apparati in una rete loro (lezione 9), con regole che permettono solo quello che serve: il PC del frigorista verso il controllore, il controllore verso il suo portale, e basta; nessuna porta industriale raggiungibile dagli uffici	un pomeriggio, se gli switch sono gestiti
4 · Guardare il traffico	in ascolto sul segmento OT: chi scrive ai PLC, chi esce verso internet (lezione 11)	dopo, quando c'è il sensore
5 · Scriverlo nel contratto	il fornitore accede quando autorizzato, su quello che gli serve, e l'accesso si registra e si revoca a fine intervento; e dice come gestisce gli aggiornamenti del firmware	una riga nel prossimo rinnovo

I primi due passi li fai da solo in una mattina e tolgono il grosso del rischio. Se non c'è la VPN, nell'urgenza va bene anche limitare la porta aperta ai soli indirizzi del fornitore: il CERT-FR lo scrive come soluzione provvisoria, e tale deve restare.

Una precisazione di ACN che merita una riga: **mettere gli apparati in una VLAN separata non basta**, se poi fra le VLAN passa tutto. Serve il firewall in mezzo, con regole che negano quello che non è stato

autorizzato, anche in uscita.

Cosa non fare

- **Non aggiornare un PLC o un controllore da solo, su due piedi.** Prima si parla con chi lo mantiene, si fa in un orario concordato, con la configurazione salvata e il modo per tornare indietro.
- **Non scansionare la rete di produzione con gli strumenti dell'informatica.** Alcuni apparati industriali si bloccano con una scansione di porte. Prima si separa, poi si ascolta, e si tocca solo alle condizioni del terzo livello.
- **Non staccare tutto senza avvisare.** Il frigorista riceve i dati del banco da remoto; se chiudi il collegamento senza dirglielo, la prima volta che il banco si ferma nessuno lo sa. Il CERT-FR ricorda anche di controllare cosa dice l'assicurazione prima di interrompere quel flusso.

Gli errori che vedo più spesso

- **«Lo gestisce il fornitore».** Vuol dire che nessuno in azienda sa come è raggiungibile e con che password. Il fornitore lo gestisce, ma la rete è tua.
- **La porta aperta «temporanea».** Aperta per un intervento, tre anni fa.
- **L'inventario senza le cose.** Server, PC e stampanti ci sono; frigo, cancelli e telecamere no, perché «non sono informatica».
- **Il router 4G del fornitore.** Un secondo accesso a internet, dentro la tua rete, che non passa dal tuo firewall e che non sapevi di avere.
- **La VLAN senza il firewall.** Gli apparati sono «separati», ma dagli uffici si arriva lo stesso alla porta 502.
- **Pensare che non interessi a nessuno.** Gli attacchi di ottobre e novembre non cercavano un supermercato in particolare: cercavano un tipo di apparato esposto, ovunque fosse.

CON L'AI, PER QUESTA LEZIONE

Uso speciale · Il censimento con un aiuto, e le domande ai fornitori. Qui l'assistente serve per due cose noiose che altrimenti non si fanno: trasformare l'elenco delle regole del firewall in un elenco di domande, e preparare la richiesta ai fornitori in un modo che non li metta sulla difensiva.

A · Dalle regole del firewall all'elenco delle porte aperte. Esporta le regole di inoltro (NAT, port forwarding) e togli gli indirizzi pubblici. Poi:

> ```
> Queste sono le regole di inoltro delle porte del firewall di un'azienda di [N] persone, senza gli indirizzi pubblici: [incolla]. Per ogni regola dimmi in una riga che tipo di servizio espone (una pagina web di gestione, un accesso remoto, una telecamera, un protocollo industriale) e quanto è rischioso che sia raggiungibile da internet. Alla fine ordinami le regole dalla più urgente da chiudere alla meno urgente, e per ognuna la domanda da fare a chi l'ha chiesta.
> ```

L'assistente riconosce le porte più comuni dal numero. Su quelle che non riconosce dice «non so»: sono proprio quelle su cui chiamare il fornitore. Non incollare mai gli indirizzi pubblici né le password.

B · La mail al fornitore. Serve una richiesta corta, che chieda i fatti senza accusare nessuno:

> Scrivi una mail di dieci righe al nostro [frigorista / manutentore della linea / installatore dell'allarme] per chiedergli: quali apparati ha installato da noi che si raggiungono dalla rete; come li raggiunge da fuori quando interviene; se la password di fabbrica è stata cambiata; che versione di firmware hanno e se il produttore la aggiorna ancora. Tono cordiale, niente termini tecnici, niente accuse: il motivo è che stiamo facendo l'inventario di tutto quello che è in rete. Chiudi proponendo di passare l'accesso da fuori attraverso la nostra VPN.

Quando arrivano le risposte, incollale all'assistente insieme all'elenco delle cinque colonne e chiedigli cosa manca ancora. Quello che manca è l'ordine del giorno della prossima telefonata.

C · Leggere quello che vede Shodan, e la cattura di Wireshark. Le pagine di Shodan sul tuo indirizzo e le statistiche delle conversazioni di Wireshark sono dense, e l'assistente le legge bene:

> Questo è quello che Shodan mostra sul nostro indirizzo pubblico, senza l'indirizzo: [incolla porte, banner e protocolli riconosciuti]. Per ogni porta dimmi che apparato c'è probabilmente dietro, cosa può fare chi la raggiunge, e se va chiusa subito o può aspettare la VPN. Poi, da questa tabella delle conversazioni catturate sul segmento degli apparati [incolla la statistica di Wireshark, con gli indirizzi sostituiti da nomi come SUPERVISORE, PLC1, FRIGO2], dimmi chi scrive verso gli apparati industriali e se c'è qualcuno che non dovrebbe.

Due avvertenze. Marca e modello dal banner sono un'ipotesi dell'assistente, non un fatto: la conferma è la pagina dell'apparato. E se gli chiedi se una versione di firmware ha falle note, può rispondere con dati vecchi: la versione la confronti tu con la pagina degli avvisi del produttore e con gli avvisi ICS di CISA, che sono di oggi.

DA FARE

Lunedì mattina, se sei l'unico informatico

1. Fai l'elenco degli apparati che comandano qualcosa di fisico: chiedi a chi li ha installati (frigorista, elettricista, chi fa l'allarme, chi segue la linea) come li raggiunge da fuori. ☐
2. Cerca il tuo indirizzo pubblico su Shodan e confrontalo con le regole di inoltro del firewall (NAT, port forwarding): chiudi gli inoltri verso gli apparati, spegni UPnP sul router. L'accesso da fuori passa dalla VPN, acceso quando serve. ☐
3. Apri una scheda di dieci righe per ogni apparato, a partire da password di fabbrica, versione del firmware e chi può dargli comandi. Se un apparato è fuori supporto e non si aggiorna, va isolato: non può stare su un indirizzo pubblico. ☐

Glossario

Le sigle nuove di questa lezione, con due righe ciascuna: la prima per capirsi, la seconda per capire. Poi, in breve, quelle delle lezioni precedenti.

OT NUOVA — La tecnologia che comanda cose fisiche: frigoriferi, macchine, cancelli, impianti (Operational Technology). L'informatica che elabora dati si chiama IT. *Per capirla meglio:* La differenza che conta per la sicurezza: un errore sull'IT fa perdere dati, un errore sull'OT fa fermare una macchina o scongelare un banco. Per questo sull'OT si aggiorna con cautela e in orari concordati, e per questo è più esposto: ha paura di cambiare.

ICS, SCADA NUOVA — I sistemi che controllano impianti industriali (Industrial Control Systems), e il software di supervisione che li comanda da un posto solo (Supervisory Control And Data Acquisition). *Per capirla meglio:* Lo SCADA è lo schermo da cui l'operatore vede e comanda tutto l'impianto; sotto ci sono i PLC che eseguono. Quando si legge «attacco a sistemi SCADA» vuol dire che qualcuno è arrivato a quello schermo, o al suo equivalente web, e ha potuto cambiare i valori.

HMI NUOVA — Il pannello, fisico o web, da cui una persona legge e comanda una macchina o un impianto (Human-Machine Interface). *Per capirla meglio:* È la «pagina web del controllore» di questa lezione. Nasce per stare nel quadro elettrico accanto alla macchina; quando viene esposta su internet per comodità, chiunque la trovi ha in mano la macchina.

Modbus NUOVA — Un protocollo industriale degli anni Settanta, ancora ovunque, con cui gli apparati si scambiano valori e comandi (porta 502). *Per capirla meglio:* Non prevede né password né cifratura: chi è nella stessa rete dell'apparato può leggere e scrivere i suoi registri, e una scrittura è un comando. Non si «mette in sicurezza» Modbus: si mette in sicurezza la rete in cui gira, separandola e lasciandoci entrare solo chi deve.

BACnet NUOVA — Il protocollo degli impianti dell'edificio: condizionamento, caldaie, luci, con cui i controllori si scambiano temperature, orari e allarmi (porta 47808). *Per capirla meglio:* Come Modbus, nella versione diffusa non ha né password né cifratura. È il protocollo che si trova dietro «il condizionamento si gestisce dall'app»: se la porta è aperta sul router, l'impianto lo gestisce chiunque.

OPC UA NUOVA — Il protocollo moderno con cui supervisori e macchine recenti si scambiano i dati dell'impianto (porta 4840). *Per capirla meglio:* È l'eccezione buona: prevede certificati, firma e cifratura. Ma li prevede, non li impone: molte installazioni girano con la sicurezza su «None» per far funzionare tutto in fretta. Quando c'è OPC UA, la domanda al fornitore è «con quale profilo di sicurezza?».

SNMP NUOVA — Il protocollo con cui si leggono, e a volte si cambiano, le impostazioni degli apparati di rete e dei dispositivi (Simple Network Management Protocol, porta 161). *Per capirla meglio:* Nelle versioni 1 e 2c la «password» è una parola in chiaro detta community, e quelle di fabbrica sono public per leggere e private per scrivere. Vanno cambiate come una password, o si passa alla versione 3, che ha utenti e cifratura. Chi legge via SNMP la configurazione di un apparato sa già dove colpire.

UPnP NUOVA — Una funzione dei router domestici e di molti aziendali con cui un dispositivo interno si fa aprire una porta da fuori da solo, senza che nessuno la configuri (Universal Plug and Play). *Per capirla meglio:* È comoda per le console di gioco ed è il modo in cui telecamere e videoregistratori finiscono esposti su internet senza che nessuno abbia aperto niente. Sul router dell'azienda si spegne, e poi si guarda l'elenco delle porte che aveva aperto.

Shodan NUOVA — Un motore di ricerca che scandaglia tutti gli indirizzi di internet e tiene in memoria cosa risponde su ogni porta: banner, modello, a volte la schermata del pannello. Censys fa lo stesso. *Per capirla meglio:* Cercare il proprio indirizzo pubblico è legale, gratuito e dura un minuto: mostra quello che un attaccante vede da mesi. Riconosce i protocolli industriali, quindi un controllore con Modbus esposto compare con la sua identità. È il secondo livello dell'audit di questa lezione.

IEC 62443 NUOVA — La norma internazionale della sicurezza dei sistemi industriali e OT, scritta per costruttori, integratori e chi gestisce l'impianto. *Per capirla meglio:* Da lì vengono le zone e i condotti: gli apparati stanno in una zona, e fra una zona e l'altra passa solo quello che è scritto nel condotto. Non la leggi tutta; la citi quando chiedi a un costruttore come ha pensato la rete della macchina, e ti aspetti che la conosca.

NVR NUOVA — Il videoregistratore di rete a cui arrivano le immagini delle telecamere (Network Video Recorder). *Per capirla meglio:* È uno degli apparati OT più diffusi nelle PMI e uno dei più esposti: la app del produttore vuole raggiungerlo da fuori, e spesso lo fa con una porta aperta sul router o passando dal cloud del produttore. Va trattato come un server: password sua, rete sua, aggiornamenti.

Firmware NUOVA — Il software che sta dentro un apparato e lo fa funzionare: router, telecamere, controllori, stampanti. *Per capirla meglio:* È il «sistema operativo» degli oggetti. Si aggiorna di rado perché nessuno lo vede e perché aggiornarlo fa paura. Quando il produttore smette di pubblicarne versioni nuove, l'apparato è fuori supporto: le falle che si scoprono da lì in avanti restano aperte per sempre.

Dalle lezioni precedenti (la spiegazione completa è nella lezione in cui sono comparse):

CIA — Le tre cose da proteggere: riservatezza, integrità, disponibilità (in inglese Confidentiality, Integrity, Availability). Niente a che vedere con l'agenzia americana. *(lezione 1)*

ransomware — Un programma che cifra i file dell'azienda e chiede un riscatto per la chiave. Non è una sigla, ma è la parola che torna più spesso. *(lezione 1)*

DDoS — Attacco che manda a un servizio più richieste di quante ne regga, finché smette di rispondere. Sta per Distributed Denial of Service. *(lezione 1)*

HTTPS — La versione cifrata di HTTP, il protocollo delle pagine web. È il lucchetto nel browser. *(lezione 1)*

PLC — Il computer industriale che comanda una macchina o una linea di produzione (Programmable Logic Controller). *(lezione 1)*

IBAN — Il codice del conto corrente, quello che si scrive per fare un bonifico (International Bank Account Number). *(lezione 1)*

AI — Intelligenza artificiale. Qui vuol dire gli assistenti con cui si parla scrivendo, e i modelli che ci stanno dietro. *(lezione 1)*

CVE — Il codice univoco di una vulnerabilità nota, nel formato CVE-anno-numero (Common Vulnerabilities and Exposures). *(lezione 2)*

CWE — La categoria di una debolezza del software, per esempio «SQL injection» (Common Weakness Enumeration). *(lezione 2)*

CVSS — Il punteggio di gravità di una vulnerabilità, da 0 a 10 (Common Vulnerability Scoring System). *(lezione 2)*

NVD — La banca dati pubblica dei CVE, gestita dal NIST americano (National Vulnerability Database). *(lezione 2)*

NIST — L'ente americano degli standard (National Institute of Standards and Technology). Gestisce l'NVD e pubblica le linee guida più usate. *(lezione 2)*

CNA — Gli enti autorizzati ad assegnare i codici CVE: grandi produttori, CERT nazionali, ricercatori accreditati (CVE Numbering Authority). *(lezione 2)*

MITRE — L'organizzazione americana senza scopo di lucro che coordina i CVE e gestisce ATT&CK. *(lezione 2)*

CERT — Una squadra che risponde agli incidenti informatici, nazionale o di settore (Computer Emergency Response Team). *(lezione 2)*

EPSS — Una stima, in percentuale, della probabilità che una vulnerabilità venga sfruttata nei prossimi trenta giorni (Exploit Prediction Scoring System). *(lezione 2)*

AV, AC, PR, UI — Le quattro lettere principali del vettore CVSS: da dove si attacca, quanto è difficile, se servono privilegi, se serve un'azione dell'utente. *(lezione 2)*

SQL — Il linguaggio con cui si interrogano le banche dati (Structured Query Language). *(lezione 2)*

XSS — Un difetto di un sito che permette di far eseguire del codice nel browser di chi lo visita (Cross-Site Scripting). *(lezione 2)*

VPN — Un collegamento cifrato da fuori verso la rete aziendale, come se si fosse in ufficio (Virtual Private Network). *(lezione 2)*

NAS — Un disco di rete condiviso, spesso usato per i file e per i backup (Network Attached Storage). *(lezione 2)*

API — Un modo per far parlare due programmi fra loro, senza passare da una pagina web (Application Programming Interface). *(lezione 2)*

KEV — Il catalogo delle vulnerabilità che vengono già sfruttate in attacchi reali, tenuto da CISA (Known Exploited Vulnerabilities). *(lezione 3)*

CISA — L'agenzia americana per la sicurezza informatica e delle infrastrutture (Cybersecurity and Infrastructure Security Agency). *(lezione 3)*

FIRST — L'associazione mondiale delle squadre di risposta agli incidenti, che calcola e pubblica l'EPSS (Forum of Incident Response and Security Teams). *(lezione 3)*

CSV — Un file di testo con i dati in colonne separate da virgole (Comma-Separated Values). Si apre con un foglio di calcolo. *(lezione 3)*

ATT&CK — Il catalogo, tenuto da MITRE, delle tattiche e tecniche che gli attaccanti usano davvero. *(lezione 4)*

TA0004, T1053 — I codici delle tattiche (TA) e delle tecniche (T) nel catalogo ATT&CK. *(lezione 4)*

C2 — Il canale con cui chi attacca comanda da remoto un computer infetto (Command and Control). *(lezione 4)*

OWASP — Una comunità mondiale che pubblica materiale gratuito sulla sicurezza delle applicazioni web (Open Web Application Security Project). *(lezione 4)*

USB — La presa a cui si attaccano chiavette, mouse, tastiere (Universal Serial Bus). *(lezione 4)*

SMS — I messaggi di testo del telefono (Short Message Service). *(lezione 5)*

QR — Il quadrato a punti che si inquadra con il telefono per aprire un indirizzo (Quick Response code). *(lezione 5)*

OTP — Il codice usa e getta che arriva per SMS o che genera un'app, da inserire oltre alla password (One-Time Password). *(lezione 5)*

SPID — L'identità digitale pubblica italiana, quella con cui si entra nei servizi della pubblica amministrazione (Sistema Pubblico di Identità Digitale). *(lezione 5)*

Ing. Alessandro Manneschi
Cyber Security Architect · NIS2, monitoraggio e sicurezza per le PMI

Tutte le lezioni, gratis:
github.com/alevento/sicurezza-per-chi-e-solo
Licenza CC BY-NC-SA 4.0